ΟΙΚΟΝΟΜΙΚΟ ΠΑΝΕΠΙΣΤΗΜΙΟ ΑΘΗΝΩΝ

ATHENS UNIVERSITY OF ECONOMICS AND BUSINESS

# Η ΕΠΙΘΕΣΗ ΣΤΗΝ ΕΦΟΔΙΑΣΤΙΚΗ ΑΛΥΣΙΔΑ ΤΗΣ SOLARWINDS: ΙΣΤΟΡΙΚΗ ΑΝΑΔΡΟΜΗ, ΤΕΧΝΙΚΗ ΑΝΑΛΥΣΗ ΚΑΙ ΣΤΡΑΤΗΓΙΚΕΣ ΑΠΟΤΡΟΠΗΣ

ΣΠΥΡΙΔΩΝ ΠΡΩΙΚΑΚΗΣ | 3220167

ΒΙΚΤΩΡΙΑ ΚΑΤΣΑΜΠΟΥΚΑ | 3190254

ΒΑΣΙΛΗΣ ΓΚΑΤΖΗΣ | 3190043

Κυβερνοασφάλεια
Εργασία ακαδημαϊκού έτους 2025-2026

# ΠΡΟΛΟΓΟΣ

Η παρούσα εργασία έχει ως στόχο να εξετάσει σε βάθος την επίθεση εφοδιαστικής αλυσίδας στη SolarWinds: αφενός ως μια κομβική μελέτη περίπτωσης για την ανατομία μιας εξαιρετικά εξελιγμένης κυβερνοαπειλής και, αφετέρου, ως σημείο αναφοράς για τον επανασχεδιασμό των σύγχρονων στρατηγικών ψηφιακής άμυνας.

Στο **Μέρος Α** πραγματοποιείται μια συνοπτική παρουσίαση του περιστατικού. Εξετάζεται το ιστορικό πλαίσιο εντός του οποίου εκδηλώθηκε η παραβίαση, καταγράφονται οι κύριοι εμπλεκόμενοι οργανισμοί και αποτιμώνται οι ευρύτερες επιπτώσεις που προκάλεσε η επίθεση σε παγκόσμιο επίπεδο.

Στο **Μέρος Β** ακολουθεί μια λεπτομερής τεχνική ανάλυση σε όλα τα στάδια της επίθεσης. Μέσα από την αποδόμηση της μεθοδολογίας των επιτιθέμενων, αναλύεται ο μηχανισμός με τον οποίο παραβιάστηκαν τα συστήματα παραγωγής, εξετάζοντας πώς μια νόμιμη διαδικασία αναβάθμισης μετατράπηκε σε «όπλο» μαζικής διείσδυσης. Παράλληλα, χαρτογραφούνται οι προηγμένες τεχνικές που εξασφάλισαν την αθόρυβη δράση της απειλής εντός του περιβάλλοντος της SolarWinds, καθώς και τη μακροχρόνια παραμονή της σε αυτό χωρίς να γίνει αντιληπτή.

Στο **Μέρος Γ** αναλύονται τα αίτια που ευθύνονται για την καθυστέρηση του εντοπισμού της παραβίασης, ρίχνοντας φως στα κενά ασφαλείας της εταιρείας, με χαρακτηριστικό παράδειγμα τη γνωστή υπόθεση διαρροής κωδικού πρόσβασης από ασκούμενο υπάλληλό της. Το κεφάλαιο ολοκληρώνεται με την παράθεση συγκεκριμένων οργανωτικών και τεχνικών μέτρων που θα μπορούσαν να είχαν αποτρέψει ή περιορίσει δραστικά την απειλή.

## Πίνακας περιεχομένων


1. Μέρος Α – Συνοπτική παρουσίαση της επίθεσης ..... 2

1.1 Εισαγωγή ..... 2

1.2 Ιστορικό πλαίσιο ..... 2

1.3 Εμπλεκόμενοι Οργανισμοί ..... 3

1.4 Έκταση και Επιπτώσεις ..... 4

2. Μέρος Β – Τεχνική Ανάλυση της επίθεσης ..... 4

2.1 Μεθοδολογία Ανάλυσης και το Πλαίσιο MITRE ATT&CK ..... 4

2.2 Στάδιο 1: Αναγνώριση (*Reconnaissance*) ..... 5

2.3 Στάδιο 2: Εργαλειοποίηση (*Weaponization*) ..... 5

2.4 Στάδιο 3: Διανομή (*Delivery*)....5
2.5 Στάδιο 4: Εκμετάλλευση (*Exploitation*)....6
2.6 Στάδιο 5: Εγκατάσταση (*Installation*) ....6
2.7 Στάδιο 6: Διοίκηση και Έλεγχος (*Command and Control - C2*) ....7
2.8 Στάδιο 7: Ενέργειες επί του Στόχου (*Actions on Objectives*) ....8
2.9 Χρονολόγιο (*Timeline*) της Επίθεσης ....8
3. Μέρος Γ – Ανάλυση της Αποτυχίας των Αμυντικών Μηχανισμών και Προτεινόμενες Πολιτικές Ασφαλείας ....9
3.1 Κατάρρευση Αμυντικών Μηχανισμών ....9
3.2 Ο κωδικός «solarwinds123» ....10
3.3 Προτεινόμενα Μέτρα Ασφαλείας ....10
4. Συμπεράσματα και Επίλογος ....11
Πηγές....12

# 1. Μέρος Α – Συνοπτική παρουσίαση της επίθεσης

## 1.1 Εισαγωγή

Τα τελευταία χρόνια, οι κυβερνοεπιθέσεις που στοχεύουν την εφοδιαστική αλυσίδα λογισμικού (*supply chain attacks*) συνιστούν μια διαρκώς διογκούμενη απειλή στο ψηφιακό οικοσύστημα. Η προτίμηση των κακόβουλων παραγόντων σε αυτήν τη μέθοδο δεν είναι τυχαία· τους παρέχει τη δυνατότητα να παρακάμψουν την προηγμένη αμυντική θωράκιση οργανισμών με ισχυρή κυβερνοάμυνα, διεισδύοντας στα δίκτυά τους μέσω έμπιστων προμηθευτών λογισμικού. Το συμβάν παραβίασης της αμερικανικής εταιρείας SolarWinds, το οποίο αποκαλύφθηκε τον Δεκέμβριο του 2020, δεσπόζει ως μία από τις πιο αντιπροσωπευτικές και επιζήμιες εφαρμογές της εν λόγω τακτικής (Martínez & Durán, 2021).

## 1.2 Ιστορικό πλαίσιο

Η αμερικανική ιδιωτική εταιρεία τεχνολογίας SolarWinds ιδρύθηκε το 1999. Κατά τη διάρκεια της ιστορίας της, κατάφερε να εντάξει στο πελατολόγιό της σχεδόν όλες τις εταιρείες του *Fortune 500*, καθώς και χιλιάδες φορείς και οργανισμούς της ομοσπονδιακής κυβέρνησης και της τοπικής αυτοδιοίκησης των ΗΠΑ (Tamašiūnas, 2021). Αυτή η τεράστια επιτυχία και η ευρεία χρήση των συστημάτων της, την κατέστησαν τον ιδανικό στόχο για την εκτέλεση μιας ευρείας κλίμακας κυβερνοεπίθεσης.

Η έναρξη της επίθεσης τοποθετείται αρκετούς μήνες πριν γίνει γνωστή, με τις έρευνες να αποδεικνύουν ότι η αρχική παραβίαση του περιβάλλοντος ανάπτυξης είχε

συντελεστεί ήδη από τον Σεπτέμβριο του 2019 (Temple-Raston, 2021). Τη συγκεκριμένη περίοδο, πραγματοποιήθηκαν οι πρώτες δοκιμαστικές τροποποιήσεις κώδικα (*test runs*) προκειμένου οι επιτιθέμενοι να ελέγξουν αν μπορούν να αλλοιώσουν τη διαδικασία παραγωγής (*build process*) χωρίς να γίνουν αντιληπτοί. Κατά τη διερεύνηση του περιστατικού, διαπιστώθηκε ότι οι δράστες υλοποίησαν μια εξαιρετικά εξελιγμένη επίθεση εφοδιαστικής αλυσίδας. Συγκεκριμένα, κατάφεραν να ενσωματώσουν κακόβουλο κώδικα, γνωστό ως *SUNBURST*, μέσα στις ψηφιακά υπογεγραμμένες ενημερώσεις του λογισμικού Orion (FireEye, 2020).

Η αποκάλυψη αυτού του τεράστιου πλήγματος στην παγκόσμια κυβερνοασφάλεια πραγματοποιήθηκε τελικά στις 13 Δεκεμβρίου 2020 όταν ένα άρθρο στην εφημερίδα *Washington Post* έκανε παγκόσμια γνωστό ότι ένας μεγάλος αριθμός κυβερνητικών φορέων και οργανισμών είχαν υποστεί επιτυχημένες επιθέσεις, οι οποίες εκκινούσαν από το παραβιασμένο λογισμικό Orion της SolarWinds (Nakashima & Timberg, 2020).

### 1.3 Εμπλεκόμενοι Οργανισμοί

Η πρωτοφανής πολυπλοκότητα της επίθεσης δεν περιορίζεται αποκλειστικά στην τεχνική αρτιότητα του κακόβουλου κώδικα, αλλά αναδεικνύεται ξεκάθαρα και από το μέγεθος των οργανισμών που ενεπλάκησαν, είτε ως επιτιθέμενοι, είτε ως θύματα.

Από την πλευρά των επιτιθέμενων, οι έρευνες των επίσημων αμερικανικών υπηρεσιών πληροφοριών ταυτοποίησαν τους δράστες ως την ομάδα προηγμένης επίμονης απειλής *APT29* (γνωστή και ως Cozy Bear). Σύμφωνα με τις αναφορές των ΗΠΑ, η συγκεκριμένη ομάδα φέρεται να συνδέεται στενά με τη ρωσική Υπηρεσία Εξωτερικών Πληροφοριών (SVR), γεγονός που, εφόσον ισχύει, καταδεικνύει το εξαιρετικά υψηλό, κρατικό επίπεδο της απειλής (US Department of State, 2021). Ωστόσο, η απόδοση ευθυνών στον κυβερνοχώρο αποτελεί μια ιδιαίτερα περίπλοκη διαδικασία. Η ρωσική κυβέρνηση αρνήθηκε κατηγορηματικά κάθε εμπλοκή στο περιστατικό, με τον επικεφαλής των ρωσικών μυστικών υπηρεσιών, Sergei Naryshkin, να φτάνει στο σημείο να υποστηρίξει ότι πίσω από την επίθεση ενδέχεται να βρίσκονταν οι ίδιες οι αμερικανικές υπηρεσίες (Reuters, 2021). Επιπλέον, το τοπίο περιπλέκεται από αναφορές που υποδεικνύουν την παράλληλη δράση και άλλων κρατικών παραγόντων. Ειδικότερα, υπάρχουν ενδείξεις ότι κινέζοι χάκερ εκμεταλλεύτηκαν επίσης το λογισμικό της SolarWinds για να στοχεύσουν αμερικανικούς κυβερνητικούς φορείς, όπως το Εθνικό Κέντρο Οικονομικών (NFC) του Υπουργείου Γεωργίας (Bing et al., 2021).

Σύμφωνα με τον Tamašiūnas (2021), όσον αφορά τα θύματα, η στόχευση της εφοδιαστικής αλυσίδας εξέθεσε περίπου 18.000 πελάτες που εγκατέστησαν την παραβιασμένη ενημέρωση. Ανάμεσά τους βρίσκονταν κρίσιμα υπουργεία των ΗΠΑ (Οικονομικών, Ενέργειας, Εσωτερικής Ασφαλείας), καθώς και η πλειοψηφία των εταιρειών της λίστας Fortune 500.

### 1.4 Έκταση και Επιπτώσεις

Η πρωτοφανής κλίμακα και η εμβέλεια του συγκεκριμένου περιστατικού οδήγησαν ανώτατα στελέχη της βιομηχανίας να το χαρακτηρίσουν ως τη μεγαλύτερη και πιο εξελιγμένη επίθεση που έχει καταγραφεί παγκοσμίως (Smith, 2021). Αν και ο αρχικός φορέας παραβίασης ήταν το λογισμικό Orion, η πραγματική έκταση της επίθεσης ξεπέρασε κατά πολύ τα όρια της κατασκευάστριας εταιρείας, προκαλώντας μια αλυσιδωτή αντίδραση (*ripple effect*) στο παγκόσμιο ψηφιακό οικοσύστημα.

Οι επιπτώσεις της επίθεσης ήταν βαθύτατες και διακρίνονται σε τρία βασικά επίπεδα:

- **Επιχειρησιακό Επίπεδο:** Οι επιτιθέμενοι απέκτησαν μακροχρόνια πρόσβαση σε κρίσιμα δεδομένα και εσωτερικές επικοινωνίες, επιτρέποντας την αθόρυβη παρακολούθηση συστημάτων για μήνες και εκθέτοντας κρίσιμες πληροφορίες πνευματικής ιδιοκτησίας (FireEye, 2020). Παράλληλα, η σοβαρότητα της παραβίασης κορυφώθηκε με την απόκτηση πρόσβασης ακόμη και στον πηγαίο κώδικα (*source code*) κορυφαίων τεχνολογικών κολοσσών, όπως η Microsoft (Microsoft, 2020a).
- **Στρατηγικό Επίπεδο:** Η επίθεση κλόνισε θεμελιωδώς την εμπιστοσύνη στις παγκόσμιες αλυσίδες παραγωγής λογισμικού (*software supply chains*). Ανέδειξε ότι η χρήση νόμιμων καναλιών ενημέρωσης λογισμικού ως «δούρειο ίππο» (*Trojan horse*) αποτελεί μια συστημική ευπάθεια, η οποία απαιτεί πλέον τον ριζικό επανασχεδιασμό των μοντέλων κυβερνοάμυνας (CISA, 2021).
- **Οικονομικό Επίπεδο:** Βάσει ερευνών της βιομηχανίας, το μέσο κόστος του περιστατικού για κάθε πληγείσα εταιρεία ανήλθε στα 12 εκατομμύρια δολάρια (Combs, 2021). Παράλληλα, οι αμερικανικές ομοσπονδιακές υπηρεσίες αναγκάστηκαν να ανακατευθύνουν τεράστιους πόρους αποκλειστικά για τη θωράκιση των υποδομών τους, επιβεβαιώνοντας την ασύμμετρη φύση της απειλής (GAO, 2021).

## 2. Μέρος Β – Τεχνική Ανάλυση της επίθεσης

### 2.1 Μεθοδολογία Ανάλυσης και το Πλαίσιο MITRE ATT&CK

Η τεχνική ανάλυση που ακολουθεί προσεγγίζει την κυβερνοεπίθεση στη SolarWinds, αναλύοντας την εξέλιξή της μέσα από τα διακριτά στάδια του κύκλου ζωής μιας σύνθετης παραβίασης. Για την εξασφάλιση της βέλτιστης επιστημονικής τεκμηρίωσης, η δράση των επιτιθέμενων χαρτογραφείται συνδυάζοντας δύο κορυφαία πρότυπα της βιομηχανίας. Αρχικά, η μακροσκοπική εξέλιξη της επίθεσης αναλύεται στα επιμέρους στάδιά της, με κάθε φάση να αντιστοιχίζεται στο καθιερωμένο μοντέλο *Cyber Kill Chain* (Lockheed Martin, 2015). Παράλληλα, σε πιο τεχνικό επίπεδο, οι τακτικές και οι τεχνικές που αναπτύχθηκαν εντός του κάθε σταδίου αντλούνται από το παγκοσμίως αναγνωρισμένο πλαίσιο *MITRE ATT&CK*. Το συγκεκριμένο πλαίσιο αποτελεί μια εκτενή, τυποποιημένη βάση γνώσεων της βιομηχανίας κυβερνοασφάλειας, η οποία βασίζεται σε πραγματικά περιστατικά. Κατηγοριοποιεί με ακρίβεια τις μεθόδους των επιτιθέμενων σε Τακτικές (*Tactics*), οι οποίες αντιπροσωπεύουν τον στρατηγικό στόχο

της επιχείρησης, και σε Τεχνικές (*Techniques*), που περιγράφουν τον συγκεκριμένο τρόπο εκτέλεσης της εκάστοτε ενέργειας (Cycraft, 2019). Με αυτόν τον τρόπο, επιτυγχάνεται η δομημένη χαρτογράφηση του τρόπου δράσης των επιτιθέμενων και των μεθόδων επηρεασμού των συστημάτων, διαμορφώνοντας παράλληλα τη βάση για το αναλυτικό χρονολόγιο (*timeline*) που παρατίθεται στο τέλος της ενότητας.

### 2.2 Στάδιο 1: Αναγνώριση (*Reconnaissance*)

Πριν από την κύρια επίθεση, η ομάδα των επιτιθέμενων διεξήγαγε μια εκτεταμένη επιχείρηση συλλογής πληροφοριών με στόχο τον εντοπισμό της βέλτιστης οδού διείσδυσης στην εφοδιαστική αλυσίδα.

- **Tactic:** Reconnaissance (**TA0043**)
- **Technique IDs:** Gather Victim Identity Information: Credentials (**T1589.001**)

Οι επιτιθέμενοι επικεντρώθηκαν στην υποκλοπή στοιχείων από τη βάση δεδομένων ηλεκτρονικού ταχυδρομείου της SolarWinds. Η συγκεκριμένη τεχνική τους επέτρεψε να δημιουργήσουν το λεπτομερές προφίλ των προγραμματιστών που έπρεπε να στοχεύσουν προκειμένου να ξεκινήσουν την επιχείρηση (Martínez & Durán, 2021). Η γνώση αυτή τους έδωσε την δυνατότητα να διεισδύσουν στο εσωτερικό δίκτυο της SolarWinds, στοχεύοντας με ακρίβεια τα άτομα που είχαν πρόσβαση στο περιβάλλον παραγωγής και μεταγλώττισης (*build environment*).

### 2.3 Στάδιο 2: Εργαλειοποίηση (*Weaponization*)

Σε αυτό το στάδιο, η απειλή μορφοποιήθηκε μέσω της ενσωμάτωσης κακόβουλου κώδικα σε νόμιμο λογισμικό.

- **Tactic:** Resource Development (**TA0042**)
- **Technique IDs:** Supply Chain Compromise: Compromise Software Supply Chain (**T1195.002**)

Οι επιτιθέμενοι χρησιμοποίησαν ως κύριο μέσο το εξειδικευμένο κακόβουλο λογισμικό *SUNSPOT*, το οποίο λειτούργησε ως εργαλείο στοχευμένης επιτήρησης της διεργασίας *MsBuild.exe* στον διακομιστή μεταγλώττισης της SolarWinds. Το SUNSPOT παρενέβη δυναμικά στον κύκλο παραγωγής (*build process*), αντικαθιστώντας αθόρυβα νόμιμο πηγαίο κώδικα με το backdoor SUNBURST (CrowdStrike, 2021). Ως αποτέλεσμα, η τεχνική αυτή προετοίμασε το έδαφος για τη διανομή του κακόβουλου λογισμικού στους οργανισμούς-στόχους κατά το επόμενο στάδιο της επίθεσης.

### 2.4 Στάδιο 3: Διανομή (*Delivery*)

Στο στάδιο αυτό η ομάδα δράσης αξιοποίησε τους επίσημους και έμπιστους διαύλους διανομής της εταιρείας για να φτάσει στους τελικούς στόχους.

- **Tactic:** Initial Access (**TA0001**)
- **Technique IDs:** Trusted Relationship (**T1199**)

Οι επιτιθέμενοι εκμεταλλεύθηκαν την έμπιστη σχέση (*Trusted Relationship*) μεταξύ της SolarWinds και των πελατών της (Mandiant, 2022) χρησιμοποιώντας τον επίσημο μηχανισμό ενημερώσεων της πλατφόρμας Orion ως «δούρειο ίππο» (*Trojan horse*) για την μαζική διανομή του παραβιασμένου πακέτου λογισμικού. Κατεβάζοντας και εγκαθιστώντας το φαινομενικά νόμιμο update, κυβερνητικοί φορείς και εταιρείες εισήγαγαν εν αγνοία τους το κακόβουλο λογισμικό στο εσωτερικό τους δίκτυο. Αυτό εξασφάλισε άμεσα στους επιτιθέμενους την απαραίτητη αρχική πρόσβαση (*Initial Access*) στα συστήματα των θυμάτων (Mandiant, 2020).

### 2.5 Στάδιο 4: Εκμετάλλευση (*Exploitation*)

Αφού το παραβιασμένο πακέτο ενημέρωσης εξαπλώθηκε μαζικά με επιτυχία, το επόμενο κρίσιμο βήμα ήταν η ενεργοποίηση και εκτέλεση του κακόβουλου κώδικα στο σύστημα του θύματος, με τρόπο που να μην κινήσει υποψίες.

- **Tactic:** Execution (**TA0002**)
- **Technique IDs:** System Binary Proxy Execution: Rundll32 (**T1218.011**)

Το SUNBURST παρέμεινε σκόπιμα σε κατάσταση αδράνειας για διάστημα έως και δύο εβδομάδων. Όταν τελικά ενεργοποιήθηκε, χρησιμοποίησε τη νόμιμη διεργασία *Rundll32* για να φορτώσει και να εκτελέσει την κακόβουλη βιβλιοθήκη *SolarWinds.Orion.Core.BusinessLayer.dll*, η οποία περιείχε τον κακόβουλο κώδικα (MITRE, 2021). Το στάδιο αυτό είχε ως αποτέλεσμα την επιτυχή μετάβαση του κακόβουλου φορτίου από ένα απλό αρχείο σε μια ενεργή διεργασία του συστήματος. Με αυτόν τον τρόπο, το SUNBURST απέκτησε την ικανότητα να εκτελεί εντολές στο εσωτερικό του συστήματος των θυμάτων, εξασφαλίζοντας την απαραίτητη λειτουργικότητα για να προχωρήσει στην τελική του εγκαθίδρυση (Installation).

### 2.6 Στάδιο 5: Εγκατάσταση (*Installation*)

Μετά την αρχική εκτέλεση, ο κύριος στόχος των επιτιθέμενων ήταν να εδραιώσουν την παρουσία τους, διασφαλίζοντας ότι το SUNBURST θα παραμείνει αόρατο και μόνιμα εγκατεστημένο στο σύστημα.

- **Tactics:** Defense Evasion (TA0005) & Persistence (TA0003)
- **Technique IDs:** Software Discovery (T1518.001), Impair Defenses (T1562.001), Event Triggered Execution: IFEO Injection (T1546.012)

Το SUNBURST, αμέσως μετά την αφύπνισή του, προχώρησε σε μία στοχευμένη αναγνώριση του περιβάλλοντος για να εντοπίσει διεργασίες Antivirus και συστήματα EDR. Το λογισμικό υπολόγιζε δυναμικά το αποτύπωμα (*hash*) των ενεργών διεργασιών του συστήματος και τα συνέκρινε με την ενσωματωμένη λίστα του (*hash matching*). Αν εντόπιζε κάποιο εργαλείο ασφαλείας, είτε διέκοπτε την εκτέλεσή του, είτε τροποποιούσε το Μητρώο (*Registry*) για να απενεργοποιήσει τις υπηρεσίες καταγραφής συμβάντων (MITRE, 2021).

Παράλληλα, για την εγκαθίδρυση του, το SUNBURST χρησιμοποίησε την τεχνική IFEO (*Image File Execution Options*) στη διεργασία *dllhost.exe*. Εκμεταλλευόμενοι αυτή τη λειτουργία των Windows μέσω τροποποίησης του Μητρώου (*Registry*), οι επιτιθέμενοι πέτυχαν την αυτόματη εκτέλεση του κακόβουλου κώδικα κάθε φορά που ξεκινούσε η συγκεκριμένη νόμιμη διεργασία, καθιστώντας το malware μια μόνιμη και κρυφή πύλη εισόδου (Mandiant, 2020).

Η χρήση τεχνικών *hash matching* κατέστησε τη λειτουργία του κώδικα μη ανιχνεύσιμη από τα συμβατικά εργαλεία ασφαλείας, ενώ η κατάχρηση της λειτουργίας IFEO εξασφάλισε τη σταθεροποίηση της παραβίασης. Με αυτόν τον τρόπο, οι επιτιθέμενοι αδρανοποίησαν την άμυνα των οργανισμών, ελαχιστοποιώντας τον κίνδυνο εντοπισμού.

### 2.7 Στάδιο 6: Διοίκηση και Έλεγχος (*Command and Control - C2*)

Εφόσον το SUNBURST βεβαιώθηκε ότι το περιβάλλον λειτουργίας ήταν απαλλαγμένο από ενεργούς μηχανισμούς εντοπισμού, ξεκίνησε τη διαδικασία επικοινωνίας με τις υποδομές των επιτιθέμενων για τη λήψη περαιτέρω οδηγιών .

- **Tactics:** Command and Control (**TA0011**)
- **Technique IDs:** Application Layer Protocol: Web Protocols **(T1071.001)** & DNS (**T1071.004**), Dynamic Resolution: Domain Generation Algorithms (**T1568.002**), Symmetric Cryptography (**T1573.001**) Multi-hop Proxy (**T1090.003)**

Η αρχική επαφή (*beaconing*) πραγματοποιήθηκε μέσω του πρωτοκόλλου DNS, αξιοποιώντας έναν Domain Generation Algorithm (*DGA*) για τη δυναμική δημιουργία subdomains (Mandiant, 2020). Με αυτόν τον τρόπο, το λογισμικό παρήγαγε συνεχώς νέες διευθύνσεις, καθιστώντας αδύνατη την πρόβλεψη και τον αποκλεισμό τους από στατικές λίστες ασφαλείας (*blocklists*). Ακόμη, σύμφωνα με μεταγενέστερες αναλύσεις (Mandiant, 2022), χρησιμοποιήθηκε συμμετρική κρυπτογράφηση (*Symmetric Cryptography*) για την προστασία των δεδομένων, διασφαλίζοντας ότι το περιεχόμενό τους παραμένει μη αναγνώσιμο από τα συστήματα ασφαλείας. Παράλληλα, αξιοποιήθηκε μια σύνθετη υποδομή Multi-hop Proxy, η οποία επέτρεπε τη δρομολόγηση της κίνησης μέσω servers που βρίσκονταν στην ίδια γεωγραφική περιοχή με το θύμα, ελαχιστοποιώντας έτσι περαιτέρω τις υποψίες. Μόνο μετά την αξιολόγηση του στόχου – και εφόσον αυτός κρινόταν υψηλού ενδιαφέροντος – η επικοινωνία κλιμακωνόταν σε κανάλι HTTP/HTTPS, με τη χρήση του πρωτοκόλλου Orion Improvement Program (*OIP*) να προσφέρει την απαραίτητη κάλυψη (Microsoft, 2020b). Με αυτόν τον τρόπο, επικέντρωσαν τους πόρους τους σε θύματα υψηλού ενδιαφέροντος, ελαχιστοποιώντας παράλληλα την έκθεση των υποδομών τους (*C2 servers*) σε λιγότερο κρίσιμα συστήματα.

### 2.8 Στάδιο 7: Ενέργειες επί του Στόχου (*Actions on Objectives*)

Έχοντας εξασφαλίσει έναν σταθερό και κρυφό δίαυλο επικοινωνίας, οι επιτιθέμενοι πέρασαν στην τελική φάση της επιχείρησης, η οποία περιλάμβανε την ενεργή πλέον παρέμβαση ανθρώπινου παράγοντα (*hands-on-keyboard activity*) εντός των παραβιασμένων δικτύων.

- **Tactics:** Lateral Movement (**TA0008**) & Exfiltration (**TA0010**)
- **Technique IDs**: Remote Services (**T1021**), Exfiltration Over Web Service (**T1567**), Forge Web Credentials: Web Cookies (**T1606.001**) & SAML Tokens (**T1606.002**)

Οι επιτιθέμενοι εκμεταλλεύτηκαν τα προνόμια που απέκτησαν και κινήθηκαν πλευρικά (*Lateral Movement*) στο εσωτερικό δίκτυο των οργανισμών. Εφαρμόζοντας την τεχνική *Golden SAML*, προχώρησαν στην κατασκευή πλαστών τεκμηρίων ταυτοποίησης (*tokens*) αποκτώντας πλήρη έλεγχο επί της διαδικασίας ταυτοποίησης (Microsoft, 2020b). Παράλληλα, μέσω της πλαστογράφησης διαδικτυακών cookies κατάφεραν να παρακάμψουν μηχανισμούς MFA (*Multi Factor Authentication*) και να αποκτήσουν πρόσβαση σε υπηρεσίες, όπως το ηλεκτρονικό ταχυδρομείο καθώς και σε κρίσιμα δεδομένα στο περιβάλλον υπολογιστικού νέφους (*cloud*) (MITRE, 2021b). Οι συνέπειες ήταν καταστροφικές, καθώς οι επιτιθέμενοι κατάφεραν να εξάγουν τεράστιους όγκους δεδομένων όπως και να κατασκοπεύουν κυβερνητικούς οργανισμούς και ιδιωτικές εταιρείες για μεγάλο χρονικό διάστημα (CISA, 2021).

### 2.9 Χρονολόγιο (*Timeline*) της Επίθεσης

Το παρακάτω χρονολόγιο αποτυπώνει τα βασικά γεγονότα και τις κρίσιμες φάσεις της εκδήλωσης της επίθεσης:

- **Σεπτέμβριος 2019 (Αρχική Παραβίαση και Δοκιμαστική Φάση):** Οι επιτιθέμενοι αποκτούν μη εξουσιοδοτημένη πρόσβαση στο δίκτυο της SolarWinds και πραγματοποιούν τις πρώτες δοκιμαστικές τροποποιήσεις κώδικα (*test runs*) (Martinez & Durán, 2021) .
- **20 Φεβρουαρίου 2020 (Ενσωμάτωση του SUNBURST):** Αναπτύσσεται το λογισμικό SUNSPOT, για την αλλοίωση της διαδικασίας μεταγλώττισης και ενσωματώνει τον κακόβουλο κώδικα του SUNBURST στον νόμιμο κώδικα της πλατφόρμας Orion (CrowdStrike, 2021).
- **Μάρτιος – Μάιος 2020 (Διανομή και Μαζική Εξάπλωση):** Η SolarWinds απελευθερώνει τις παραβιασμένες ενημερώσεις, οι οποίες εγκαθίστανται από χιλιάδες πελάτες, παρέχοντας στους επιτιθέμενους αρχική πρόσβαση σε κρίσιμες υποδομές (FireEye, 2020).
- **Ιούνιος 2020 (Αφαίρεση Ιχνών από την Πηγή):** Οι επιτιθέμενοι αφαιρούν το SUNBURST από το περιβάλλον της SolarWinds για να καλύψουν τα ίχνη της αρχικής παραβίασης (Martinez & Durán, 2021).

- **13 Δεκεμβρίου 2020 (Δημόσια Αποκάλυψη):** Η SolarWinds και η FireEye δημοσιοποιούν την παραβίαση, ενώ η CISA εκδίδει κατεπείγουσα οδηγία για την αποσύνδεση των συστημάτων Orion (CISA, 2021).

## 3. Μέρος Γ – Ανάλυση της Αποτυχίας των Αμυντικών Μηχανισμών και Προτεινόμενες Πολιτικές Ασφαλείας

### 3.1 Κατάρρευση Αμυντικών Μηχανισμών

Η επιτυχής εξέλιξη της επίθεσης δεν οφείλεται μόνο στην τεχνική αρτιότητα των επιτιθέμενων, αλλά και σε μεγάλο ποσοστό στις θεμελιώδεις συστημικές αδυναμίες, τόσο εντός της κατασκευάστριας εταιρείας όσο και στους οργανισμούς-πελάτες:

**1. Κουλτούρα «Τυφλής Εμπιστοσύνης»:** Το μεγαλύτερο οργανωτικό σφάλμα κατά το στάδιο της διανομής του παραβιασμένου λογισμικού ήταν η τυφλή αποδοχή της ταυτότητας του προμηθευτή (*implicit trust*). Οι οργανισμοί-στόχοι παρείχαν στο λογισμικό Orion υπερβολικά δικαιώματα διαχειριστή στα δίκτυά τους. Επειδή το update προερχόταν από μια «αξιόπιστη» πηγή, οι ομάδες ασφαλείας δεν είχαν θεσπίσει διαδικασίες ελέγχου (όπως *behavioral monitoring*) για το τι ακριβώς κάνει το λογισμικό μετά την εγκατάστασή του (Buresh, 2022).

**2. Ελλιπής Εποπτεία του Περιβάλλοντος Παραγωγής:** Εντός της SolarWinds, υπήρχε σοβαρό κενό στην παρακολούθηση των εσωτερικών συστημάτων. Το περιβάλλον μεταγλώττισης δεν ήταν επαρκώς απομονωμένο. Η απουσία αυστηρών οργανωτικών ελέγχων ακεραιότητας (*integrity checks*) στον πηγαίο κώδικα λίγο πριν την τελική έκδοση του λογισμικού, ήταν αυτό που επέτρεψε στο SUNSPOT να δράσει ανενόχλητο κατά το στάδιο του *Weaponization* (Crowdstrike, 2021).

**3. Ανεπιτυχής Συσχέτιση των Ειδοποιήσεων:** Κατά το στάδιο επικοινωνίας Command & Control (C2), οι ομάδες των Κέντρων Επιχειρήσεων Ασφαλείας (SOC) απέτυχαν να συσχετίσουν τις δικτυακές ανωμαλίες με το πρόσφατο update. Όπως αποκάλυψε η FireEye (2020), το SUNBURST καμουφλαρίστηκε τέλεια, μιμούμενο το νόμιμο πρόγραμμα βελτίωσης OIP ( *Orion Improvement Program*) της SolarWinds. Σύμφωνα με την ανάλυση της Cybereason (2021), λόγω της κατακερματισμένης παρακολούθησης των συστημάτων (*siloed monitoring),* οι αναλυτές εστίαζαν σε μεμονωμένα γεγονότα και οι ειδοποιήσεις δεν συνδυάστηκαν ποτέ. Αντιθέτως, τα ίχνη χάθηκαν στον τεράστιο όγκο των καθημερινών ειδοποιήσεων (*alert fatigue*) και αγνοήθηκαν ως «ψευδώς θετικά», καθώς αποδόθηκαν στη φυσιολογική λειτουργία ενός εκ των προτέρων (*a priori*) έμπιστου διακομιστή.

**4. Ανεπαρκής Σχεδιασμός Δικτύου και Αρχιτεκτονικά Κενά:** Σε επίπεδο σχεδιασμού δικτύου, οι οργανισμοί-πελάτες αντιμετώπιζαν το λογισμικό τρίτων ως ένα αδιαπέραστο «μαύρο κουτί» (*black box*). Δεν υπήρχε η αρχιτεκτονική απαίτηση για τη διενέργεια τακτικών ελέγχων ή αυστηρού φιλτραρίσματος στην εξερχόμενη κίνηση (*egress filtering*) των εργαλείων διαχείρισης δικτύου. Όπως επισήμανε στην επίσημη οδηγία της η αμερικανική Υπηρεσία Κυβερνοασφάλειας (CISA, 2021), τα συστήματα

αυτά δεν θα έπρεπε να έχουν ανεξέλεγκτη πρόσβαση στο διαδίκτυο. Αυτό το αρχιτεκτονικό κενό στα firewalls επέτρεψε στο SUNBURST να εξάγει δεδομένα για μήνες, καθώς η επικοινωνία του Orion με εξωτερικούς διακομιστές επιτρεπόταν *by-default* από την πολιτική ασφαλείας.

### 3.2 Ο κωδικός «solarwinds123»

Το περιστατικό του αδύναμου κωδικού «solarwinds123» σε ιδιωτικό αποθετήριο στο GitHub - το οποίο παραδόξως παρείχε δικαίωμα πρόσβασης στον update server της εταιρείας (IT Pro, 2021) - αποτέλεσε σημείο έντονης κριτικής στο Κογκρέσο το 2021, με τη διοίκηση της Solarwinds να αποδίδει το σφάλμα σε ασκούμενο υπάλληλο (CNN, 2021). Παρόλο που δεν υπάρχουν σαφείς ενδείξεις ότι ο κωδικός αυτός αποτέλεσε το σημείο εισόδου για την επίθεση, η ύπαρξή του παραμένει αδιάψευστο τεκμήριο κακής οργανωτικής κουλτούρας. Αναδεικνύει σοβαρές ελλείψεις στις βασικές αρχές ασφαλείας και εποπτείας, αδυναμίες που συχνά διευκολύνουν την επιτυχία εξελιγμένων επιθέσεων, λειτουργώντας ως το υπόστρωμα για την κατάρρευση των ευρύτερων αμυντικών μηχανισμών.

### 3.3 Προτεινόμενα Μέτρα Ασφαλείας

Η προστασία από σύνθετες κυβερνοεπιθέσεις απαιτεί τη λειτουργία πολλαπλών και αλληλοσυμπληρούμενων επιπέδων ασφαλείας. Στην περίπτωση της SolarWinds, η εφαρμογή συγκεκριμένων οργανωτικών και τεχνικών μέτρων θα μπορούσε να είχε ανακόψει τη δράση των επιτιθέμενων σε κρίσιμα στάδια ή να είχε διασφαλίσει τον έγκαιρο εντοπισμό τους πριν την ολοκλήρωση της παραβίασης.

**Οργανωτικά Μέτρα:**

- **Zero Trust Architecture:** Σύμφωνα με τον οργανισμό NIST (2020), η φιλοσοφία του Zero Trust καταργεί την έννοια της προκαθορισμένης εμπιστοσύνης, απαιτώντας συνεχή επαλήθευση για κάθε αίτημα πρόσβασης, ανεξάρτητα από την τοποθεσία του χρήστη ή του συστήματος. Στην περίπτωση της SolarWinds, η προσέγγιση αυτή θα είχε εμποδίσει την «πλευρική μετακίνηση» (lateral movement) των επιτιθεμένων, καθώς κάθε προσπάθεια του λογισμικού Orion να επικοινωνήσει με ευαίσθητα τμήματα του δικτύου ή εξωτερικούς διακομιστές ελέγχου (C2) θα αντιμετωπιζόταν ως μη εξουσιοδοτημένη ενέργεια, απαιτώντας εκ νέου αυστηρή επαλήθευση.
- **Software Bill of Materials (SBOM)**: Αποτελεί μια πλήρη απογραφή των στοιχείων και των εξαρτήσεων του λογισμικού. Στην περίπτωση της SolarWinds, η έλλειψη SBOM στέρησε από τους οργανισμούς την ορατότητα στο εσωτερικό του Orion, καθιστώντας αδύνατο τον εντοπισμό του παραβιασμένου κώδικα. Η υιοθέτησή του επιτρέπει την επαλήθευση της «προέλευσης» (*provenance*) του κώδικα και τον ταχύ εντοπισμό ευπαθειών. Η απαίτηση για SBOM καθιερώθηκε ως διεθνές πρότυπο μετά το συμβάν, με

στόχο τη διαφάνεια και τη θωράκιση της εφοδιαστικής αλυσίδας (The White House, 2021).

**Τεχνικά Μέτρα:**

- **Ανάλυση Σύνθεσης Λογισμικού (SCA):** Η χρήση εργαλείων SCA (*Software Composition Analysis)*, όπως το Dependency Graph και το Dependabot της GitHub, προσφέρει στους οργανισμούς πλήρη ορατότητα στο εσωτερικό του λογισμικού, επιτρέποντας τη χαρτογράφηση των άμεσων και μεταβατικών εξαρτήσεών του (*direct and transitive dependencies*). Με αυτόν τον τρόπο, διασφαλίζεται ο έγκαιρος εντοπισμός ευπαθειών και μειώνεται δραστικά το ρίσκο από τη χρήση μη ελεγμένου κώδικα τρίτων (Yang, Lee and McDonald, 2022).
- **Ανίχνευση DGA μέσω Μηχανικής Μάθησης:** Η εφαρμογή μοντέλων Μηχανικής Μάθησης (όπως Random Forests ή CNN/LSTM) επιτρέπει την αναγνώριση στατιστικών ανωμαλιών στα DNS queries, όπως η υψηλή εντροπία και τα n-gram patterns. Η ενσωμάτωση αυτών των μοντέλων σε συστήματα SIEM (*Security Information and Event Management*) επιτρέπει την ανίχνευση domains που παράγονται μέσω DGA (*Domain Generation Algorithm*) με εξαιρετικά υψηλά ποσοστά ακρίβειας (Biros and Kantor, 2025).
- **Θέσπιση Προτύπων Reproducible Builds:** Η επιβολή ντετερμινιστικών διαδικασιών μεταγλώττισης διασφαλίζει ότι ο ίδιος πηγαίος κώδικας παράγει πάντα ταυτόσημο εκτελέσιμο αρχείο. Σύμφωνα με το άρθρο της Linux Foundation (2021), η χρήση *verified reproducible builds* είναι μια διαδικασία κατά την οποία ανεξάρτητοι φορείς επαληθεύουν ότι το τελικό προϊόν αντιστοιχεί στον δηλωμένο κώδικα. Η υιοθέτηση αυτού του προτύπου θα επέτρεπε στη SolarWinds να εντοπίσει ότι ο παραβιασμένος εκτελέσιμος κώδικας παρουσίαζε αποκλίσεις από τον καθαρό πηγαίο κώδικα, αποκαλύπτοντας την παρέμβαση στον build server παρά την ύπαρξη έγκυρης ψηφιακής υπογραφής.

## 4. Συμπεράσματα και Επίλογος

Η επίθεση στη SolarWinds δεν αποτέλεσε απλώς μια ακόμα κυβερνοεπίθεση μεγάλης κλίμακας, αλλά μια δομική αποκάλυψη των τρωτών σημείων του σύγχρονου ψηφιακού κόσμου. Η ικανότητα των επιτιθέμενων να μετατρέψουν έναν έμπιστο μηχανισμό ενημέρωσης λογισμικού σε «όπλο» μαζικής διείσδυσης, κατέρριψε οριστικά το παραδοσιακό μοντέλο ασφάλειας που βασιζόταν στην πρότερη εμπιστοσύνη προς τους προμηθευτές.

Το κυριότερο συμπέρασμα από την υπόθεση SolarWinds είναι η ανάγκη για μετάβαση σε μια κουλτούρα «διαρκούς επαλήθευσης». Η υιοθέτηση αρχιτεκτονικών Zero Trust καθώς και η διασφάλιση της ακεραιότητας των build pipelines δεν αποτελούν πλέον προαιρετικές βελτιώσεις, αλλά θεμελιώδεις προϋποθέσεις για την επιβίωση των οργανισμών. Η επίθεση στην SolarWinds μας υπενθύμισε με τον πιο ηχηρό τρόπο ότι

στην κυβερνοασφάλεια, δεν είμαστε τόσο ισχυροί όσο οι δικοί μας «τοίχοι», αλλά όσο ο πιο αδύναμος κρίκος στην αλυσίδα των συνεργατών μας.

## Πηγές


**Bing, C., Stubbs, J., Satter, R. & Menn, J. (2021)** Exclusive: Suspected Chinese hackers used SolarWinds bug to spy on U.S. payroll agency. *Reuters*. [Online] 2nd February. Available from: https://www.reuters.com/article/us-cyber-solarwinds-china-exclusive-idUSKBN2A22K8/ [Accessed 31st March 2026].

**Biros, H. & Kantor, M. (2025)** Enhancing DGA Detection with Machine Learning Algorithms. *Journal of Telecommunications and Information Technology*. [Online] 31-44. Available from: https://www.researchgate.net/publication/389670934_Enhancing_DGA_Detection_with_Machine_Learning_Algorithms [Accessed 1st April 2026].

**Buresh, D. L. (2022)** The Solar Winds Cyber-Attack, The Federal and Private Sector Response, and the Recommendations and Lessons Learned. *International Journal of Social Science And Human Research*. [Online] 5 (10), 3469-3479. Available from: https://www.academia.edu/96839243/The_Solar_Winds_Cyber_Attack_The_Federal_and_Private_Sector_Response_and_the_Recommendations_and_Lessons_Learned [Accessed 31st March 2026].

**CISA (2021)** Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations. [Online] Available from: https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a [Accessed 1st April 2026].

**CNN. (2021)** *SolarWinds password was 'solarwinds123', intern blamed*. [Online] 26th February. Available from: https://edition.cnn.com/2021/02/26/politics/solarwinds123-password-intern [Accessed 2nd April 2026].

**Combs, V. (2021)** Cybersecurity study: SolarWinds attack cost affected companies an average of $12 million. *TechRepublic*. [Online] 28th June. Available from: https://www.techrepublic.com/article/cybersecurity-study-solarwinds-attack-cost-affected-companies-an-average-of-12-million/ [Accessed 18th March 2026].

**Cybereason (2021)** SolarWinds Attacks Highlight Importance of Operation-Centric Approach. [Online] Available from: https://www.cybereason.com/blog/solarwinds-attacks-highlight-importance-of-operation-centric-approach [Accessed 1st April 2026].

**CyCraft (2019)** MITRE ATT&CK vs. Cyber Kill Chain vs. Diamond Model. *Medium*. [Online] 15th August. Available from: https://medium.com/cycraft/cycraft-classroom-mitre-att-ck-vs-cyber-kill-chain-vs-diamond-model-1cc8fa49a20f [Accessed 31st March 2026].

**FireEye (2020)** Highly Evasive Attacker Leverages SolarWinds Supply Chain to Compromise Multiple Global Victims With SUNBURST Backdoor. *Google Cloud Threat Intelligence*. [Online] 13th December. Available from: https://cloud.google.com/blog/topics/threat-intelligence/evasive-attacker-leverages-solarwinds-supply-chain-compromises-with-sunburst-backdoor [Accessed 18th March 2026].

**Fortinet (2021)** SolarWinds supply chain attack. [Online] Available from: https://www.fortinet.com/resources/cyberglossary/solarwinds-cyber-attack [Accessed 31st March 2026].

**GAO (2021)** Cybersecurity: Federal Response to SolarWinds and Microsoft Exchange Incidents. GAO-22-104746. [Online] *U.S. Government Accountability Office*. Available from: https://www.gao.gov/products/gao-22-104746 [Accessed 18th March 2026].

**IT Pro. (2021)** *Intern blamed for weak password that may have sparked SolarWinds*. [Online] 1st March. Available from: https://www.itpro.com/security/cyber-attacks/358738/intern-blamed-for-weak-password-that-may-have-sparked-solarwinds [Accessed 2nd April 2026].

**Linux Foundation (2021)** Preventing Supply Chain Attacks Like SolarWinds. [Online] Available from: https://www.linuxfoundation.org/blog/blog/preventing-supply-chain-attacks-like-solarwinds [Accessed 1st April 2026].

**Lockheed Martin (2015)** Gaining the advantage: Intelligence-driven computer network defense. [Online] Available from: https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/Gaining_the_Advantage_Cyber_Kill_Chain.pdf [Accessed 31st March 2026]

**Mandiant (2022)** Assembling the Russian nesting doll: UNC2452 merged into APT29. Google Cloud Blog. [Online] 27th April. Available from: https://cloud.google.com/blog/topics/threat-intelligence/unc2452-merged-into-apt29 [Accessed 31st March 2026].

**Martínez, J. & Durán, J. M. (2021)** Software supply chain attacks, a threat to global cybersecurity: SolarWinds' case study. *International Journal of Safety and Security Engineering*. [Online] 11 (5), 537-545. Available from: https://iieta.org/sites/default/files/pdf/2021-11/11.05_05.pdf [Accessed 30th March 2026].

**Microsoft (2020a)** Microsoft Internal Solorigate Investigation Update. *Microsoft Security Response Center*. [Online] 31st December. Available from: https://www.microsoft.com/en-us/msrc/blog/2020/12/microsoft-internal-solorigate-investigation-update [Accessed 18th March 2026].

**Microsoft (2020b)** Analyzing Solorigate, the compromised DLL file that started a sophisticated cyberattack, and how Microsoft Defender helps protect customers. *Microsoft Security Blog*. [Online] 18th December. Available from: https://www.microsoft.com/en-us/security/blog/2020/12/18/analyzing-solorigate-the-compromised-dll-file-that-started-a-sophisticated-cyberattack-and-how-microsoft-defender-helps-protect/ [Accessed 18th March 2026].

**MITRE ATT&CK (2021)** SUNBURST, Software S0559. [Online] Available from: https://attack.mitre.org/software/S0559/ [Accessed 31st March 2026].

**MITRE ATT&CK (2021b)** SolarWinds compromise, Campaign C0024. [Online] Available from: https://attack.mitre.org/campaigns/C0024/ [Accessed 28th March 2026].

**Nakashima, E. & Timberg, C. (2020)** Russian government spies are behind a broad hacking campaign that has breached U.S. agencies and a top cyber firm. *The Washington Post*. [Online] 13th December. Available from: https://www.washingtonpost.com/national-security/russian-government-spies-are-behind-a-broad-hacking-campaign-that-has-breached-us-agencies-and-a-top-cyber-firm/2020/12/13/d5a53b88-3d7d-11eb-9453-fc36ba051781_story.html [Accessed 31st March 2026].

**NIST (2020)** Special Publication 800-207: Zero Trust Architecture. [Online] *U.S. Department of Commerce*. Available from: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf [Accessed 1st April 2026].

**Reuters (2021)** Russian spy chief denies SVR was behind SolarWinds cyber attack - BBC. *Reuters*. [Online] 18th May. Available from: https://www.reuters.com/technology/russian-spy-chief-denies-svr-was-behind-solarwinds-cyber-attack-bbc-2021-05-18/ [Accessed 31st March 2026].

**Smith, B. (2021)** SolarWinds: How Russian spies hacked the Justice, State, Treasury, Energy and Commerce Departments. *CBS News*. [Online] 14th February. Available from: https://www.cbsnews.com/news/solarwinds-hack-russia-cyberattack-60-minutes-2021-02-14/ [Accessed 18th March 2026].

**Tamašiūnas, L. (2021)** SolarWinds hack: All the details you need to know. *NordVPN*. [Online] 12th May. Available from: https://nordvpn.com/blog/solarwinds-hack/ [Accessed 31st March 2026].

**Temple-Raston, D. (2021)** A 'worst nightmare' cyberattack: The untold story of the SolarWinds hack. [Online] Available from: https://www.npr.org/2021/04/16/985439655/a-worst-nightmare-cyberattack-the-untold-story-of-the-solarwinds-hack [Accessed 31st March 2026].

**US Department of State (2021)** Holding Russia to Account. [Online] Available from: https://2021-2025.state.gov/holding-russia-to-account/ [Accessed 18th March 2026].

**The White House (2021)** Executive Order 14028: Improving the Nation's Cybersecurity. [Online] Available from: https://www.federalregister.gov/documents/2021/05/17/2021-10460/improving-the-nations-cybersecurity [Accessed 1st April 2026].

**Yang, J., Lee, Y. & McDonald, A.P. (2022)** SolarWinds Software Supply Chain Security: Better Protection with Enforced Policies and Technologies. In: *Software Engineering, Artificial Intelligence, Networking and Parallel/Distributed Computing*. Springer Nature Switzerland AG. [Online] Available from: https://www.researchgate.net/publication/357541175_SolarWinds_Software_Supply_Chain_Security_Better_Protection_with_Enforced_Policies_and_Technologies [Accessed 1st April 2026].